

DAY 10 – Advanced Phishing Analysis (Headers, URLs, Indicators)

Objective

The objective of this session is to develop advanced skills in **phishing detection and analysis**, focusing on email headers, malicious URLs, and identifying sophisticated phishing indicators used in real-world cyber attacks.

By the end of this session, learners will be able to:

- Analyze email headers to detect spoofing attempts
- Inspect URLs for malicious patterns
- Identify advanced phishing techniques
- Use threat intelligence tools for validation
- Perform structured phishing investigations
- Recommend appropriate SOC response actions

1. Email Header Analysis

Email headers provide detailed technical information about how an email was sent and routed.

1. From Address vs Return-Path mismatch

- **From Address:** What the user sees
- **Return-Path:** Actual sender

Mismatch indicates spoofing

2. Received Fields (trace email path)

- Show the path the email took through servers
- Helps trace the origin of the email

3. SPF, DKIM, DMARC Results

Protocol	Purpose	Indicator
SPF (Sender Policy Framework)	Verifies sender IP	Fail = Suspicious
DKIM (DomainKeys Identified Mail)	Email integrity check	Fail = Tampered
DMARC	Policy enforcement	Fail = High risk

Example Header :

From: support@bank.com

Return-Path: attacker@fake-domain.ru

SPF: Fail

DKIM: Fail

Analysis

- Domain mismatch → spoofing
- SPF & DKIM failure → email not authenticated
- High probability of phishing

2. URL Analysis Techniques

Phishing emails often include malicious links designed to steal credentials.

1. Chell Domain Spelling (Typosquatting)

- Example: paypal.com instead of paypal.com

2. Use of IP Address Instead of Domain

- Example: http://192.168.1.10/login
- Indicates suspicious or hidden identity

3. Shortened URLs (bit.ly etc.)

- Example: bit.ly/xyz123
- Used to hide real destination

4. HTTPS does NOT guarantee safety

- HTTPS **does not** guarantee safety
- Attackers can use SSL certificates

3. Advanced Phishing Indicators

1. Credential Harvesting Pages

- Fake login pages to steal credentials

2. Look-Alike Domains

- Domains visually similar to real ones

3. Attachments-Based Malware

- Files containing malware (PDF, DOC, EXE)

4. Business Email Compromise (BEC)

- Impersonation of executives or employees
- Used for financial fraud

4. Phishing Investigation Workflow

A structured approach is critical for accurate analysis:

1. Step 1: Analyze Email Header

- Check sender authenticity
- Verify SPF, DKIM, DMARC

2. Step 2: Inspect URLs and Domains

- Check domain structure
- Identify suspicious patterns

3. Step 3: Check Reputation (Virus Total)

- Use tools like **VirusTotal**
- Verify domain/IP reputation

4. Step 4: Identify Phishing Type

- Credential harvesting
- Malware delivery
- BEC

5. Step 5: Decide Impact & Response

- Determine if user interacted
- Check for compromise

5. SOC Response

- Once a phishing attack is **confirmed**, SOC analysts must respond quickly to **contain, eliminate, and prevent further impact**. The response is both **immediate (containment)** and **long-term (prevention)**.

1. Block Domain and Sender

What it means

- Blocking the **malicious email sender and domain** to prevent further emails from reaching users.

How it is done

- Add sender email to **email security blacklist**
- Block domain at:
 - Email gateway
 - Firewall / Proxy
 - DNS filtering systems

Why it is important

- Stops additional phishing emails
- Prevents future communication from attacker
- Reduces spread across organization

SOC Insight

- Attackers often reuse domains → blocking early prevents wider impact.

2. Remove Emails from Inbox (Email Purge)

What it means

- Removing the phishing email from **all user inboxes**, even if already delivered.

How it is done

- Use tools like:
 - Microsoft 365 (Search & Purge)
 - Google Workspace Security tools
- Identify email using:

- Subject
- Sender
- Message ID

Why it is important

- Prevents users from clicking malicious links
- Reduces risk of credential theft
- Limits internal spread

SOC Insight

- Even one missed email can lead to compromise → **complete purge is critical**

3. Reset Compromised Accounts

What it means

- Securing accounts that may have been exposed or compromised.

Actions involved

- Force password reset
- Invalidate active sessions
- Enable **Multi-Factor Authentication (MFA)**
- Review login activity

Why it is important

- Prevents attacker from maintaining access
- Stops further misuse of account
- Protects sensitive data

SOC Insight

- If login was successful → treat account as **fully compromised**

4. Create Detection Rules for Similar Attacks

What it means

- Improving detection systems (SIEM/Email Security) to catch similar attacks in the future.

How it is done

- Create SIEM rules based on:
 - Failed SPF/DKIM
 - Suspicious domains
 - Email patterns (keywords, links)
- Add Indicators of Compromise (IOCs):
 - Malicious IPs
 - Domains
 - URLs

Why it is important

- Prevents repeated attacks
- Improves detection accuracy
- Reduces false negatives

SOC Insight

- Good SOC teams don't just respond — they **learn and improve detection continuously**

Complete SOC Response Flow

- Detect phishing email
- Confirm malicious indicators
- Block sender/domain
- Remove emails from all inboxes
- Secure affected accounts
- Update detection rules
- Monitor for further activity

Real-World SOC Thinking

- A mature SOC always focuses on:
- **Containment → Elimination → Prevention**
- Not just fixing the current issue, but ensuring:
 - Attack cannot repeat
 - Similar patterns are detected early

6. Example Phishing Analysis Report

➤ Incident Report

Title: Phishing Email – Credential Harvesting Attempt

Date: April 10

Source: attacker@fake-domain.ru

Target: Employee email users

Description :

A phishing email was received impersonating a bank support team. The email contained a malicious link directing users to a fake login page designed to steal credentials.

Findings :

- Return-Path mismatch
- SPF & DKIM failed
- Suspicious shortened URL
- Fake login page detected

Severity :

High

Actions Taken :

- Blocked sender domain
- Removed phishing emails from inboxes
- Reset affected user credentials
- Updated detection rules

Status :

Resolved

7. Best Practices for Phishing Analysis

- Always verify email authenticity
- Do not trust visible sender address
- Analyze URLs before clicking
- Use threat intelligence tools
- Document findings properly

Assignment - Phishing Analysis

Task 1: Analyze Email Header

Given Example

From: support@bank.com
Return-Path: attacker@fake-domain.ru
SPF: Fail
DKIM: Fail

Analysis :

1. From vs Return-Path Mismatch

- **From:** support@bank.com (appears legitimate)
- **Return-Path:** attacker@fake-domain.ru (actual sender)

Conclusion:

This is a clear case of **email spoofing**, where the attacker disguises the sender to look like a trusted entity.

2. Authentication Failures

- **SPF: Fail** → Sender IP is not authorized for the domain
- **DKIM: Fail** → Email integrity cannot be verified

Conclusion:

The email is **not authenticated**, indicating it may be forged or manipulated.

Final Header Assessment :

- Spoofed sender identity
- Failed authentication checks
- High probability of phishing

Task 2: Identify SPF/DKIM Issues

➤ SPF (Sender Policy Framework)

Purpose:

Verifies whether the sending mail server is authorized to send emails for that domain.

Why SPF Failed

- Email was sent from an **unauthorized server/IP**
- Domain (bank.com) does not allow that IP

➤ **DKIM (DomainKeys Identified Mail)**

Purpose:

Ensures the email content has not been altered during transit.

Why DKIM Failed

- Email was modified or not properly signed
- Signature does not match domain

Combined Risk

When both SPF and DKIM fail:

- Email authenticity is compromised
- Strong indicator of phishing or spoofing

Task 3: Break Down Malicious URL

Example Suspicious URL

<http://paypal-login-secure.com/verify>

Analysis :

1. Typosquatting

- “paypal” uses capital “I” instead of “l”
- Designed to trick users visually

2. Suspicious Domain Structure

- Contains words like **login, secure, verify**
- Common in phishing URLs

3. HTTP Instead of HTTPS

- No encryption → unsafe communication

(Even HTTPS can be malicious, but HTTP is more suspicious)

4. Fake Landing Page Behavior

- Redirects to login page
- Captures credentials

Conclusion :

The URL is designed for **credential harvesting**, making it a phishing link.

Task 4: Full Phishing Investigation Report

➤ Incident Report

Title: Phishing Email – Credential Harvesting Attempt

Date: April 10

Target: Organization Users

Source: attacker@fake-domain.ru

Description:

A phishing email impersonating a legitimate bank support service was detected. The email contained a malicious link directing users to a fake login page designed to steal credentials.

Findings :

- Mismatch between From and Return-Path
- SPF and DKIM authentication failed
- Suspicious domain and typosquatting detected
- Malicious URL leading to fake login page

Severity :

High

Reason:

- Attempt to steal user credentials
- Potential account compromise
- Risk of unauthorized access

Actions Taken :

- Blocked sender domain and IP

- Removed phishing emails from user inboxes
- Reset passwords for affected users
- Added domain to blacklist
- Updated email filtering rules

Impact Assessment :

- No confirmed widespread compromise (if detected early)
- Potential risk to user credentials
- High impact if users interacted with the link

Status :

Resolved

Final Summary :

- Email is **spoofed and unauthenticated**
- URL is **malicious and designed for credential theft**
- Attack type: **Phishing (Credential Harvesting)**
- Severity: **High**

Conclusion

Advanced phishing attacks are highly sophisticated and require **deep analysis of headers, URLs, and indicators.**

SOC analysts must combine:

- Technical analysis
- Threat intelligence
- Structured workflows

to effectively detect and respond to phishing threats.

Key Takeaway

“Phishing is not just about emails — it’s about deception. A good analyst looks beyond what is shown and verifies what is real.”